Digital Health Record Management System (DHRMS)

LAB 5: UML Sequence & Activity Diagram Modeling — Interaction Scenarios & Dynamic Workflow Control

Course: Software Engineering (SWE) Academic Session 2026–2027	**Faculty Guide:** Mr. Navdesh Singh, Dept. of CSE	**Baseline:** DHRMS SRS v2.0 (ISO/IEC/IEEE 29148)

1. Laboratory Objectives & Behavioral Modeling Principles

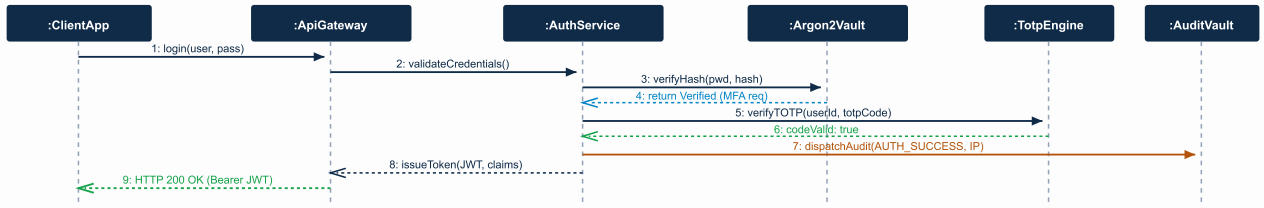
LAB DELIVERABLE 5

The objective of this laboratory is to design the formal dynamic interaction and execution semantics for DHRMS using **UML Sequence Diagrams** (for synchronous/asynchronous chronological message flow) and **UML Activity Diagrams** (for business process routing, token concurrency, and branch guard evaluation). These models formally substantiate use cases UC-01 through UC-10 and enforce Business Rules BR-01 through BR-05.

> **Behavioral Modeling Conventions & Standard Formalisms:** Sequence lifelines represent active system boundaries, microservices, and databases. Solid arrows with filled heads represent synchronous calls; dashed arrows with open heads represent return messages. Activity nodes use swimlane partitioning, decision diamonds, and fork/join synchronizers to model parallel transaction boundaries.

2. Scenario 1: User Authentication & Multi-Factor Verification (UC-01)

SEQUENCE DIAGRAM



Sequence Protocol Invariants:

- **Argon2id Verification:** Passwords are never compared in plaintext; work factors and salts execute strictly within the memory-hard vault.
- **Time-Limited Claims:** Issued JWTs contain signed role claims, user UUID, and a non-extendable 15-minute expiration timestamp.

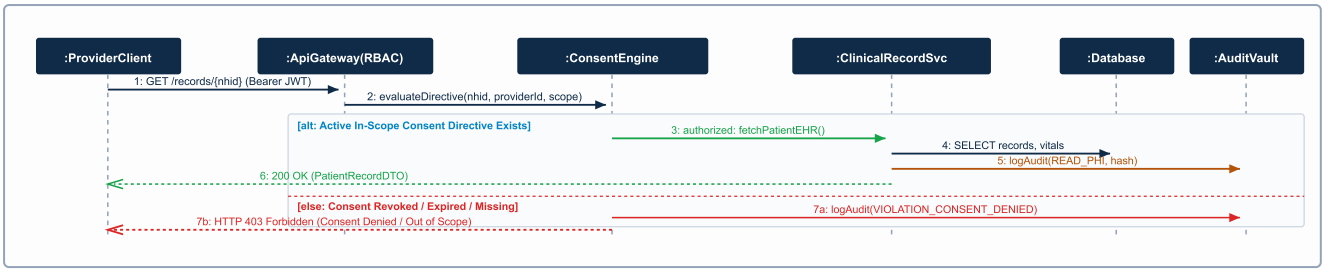
Negative & Alternative Paths:

- **Failed Credential:** Returns generic HTTP 401 without user enumeration; failure count increments in Redis cache.
- **Account Lockout:** Reaching 5 consecutive failures trips an automated security lockout and dispatches an immutable audit alert.

3. Scenario 2: Dynamic Patient Consent Verification & EHR Retrieval (UC-02 & UC-03)

SEQUENCE DIAGRAM

This scenario models the core clinical access path where a certified Healthcare Provider queries patient clinical records. The interaction realizes Business Rules **BR-01, BR-02, and BR-03**, enforcing server-side consent evaluation before any Protected Health Information (PHI) is materialized from persistent tables.



4. Message Exchange Specification & Guard Conditions

EXECUTION STEPS

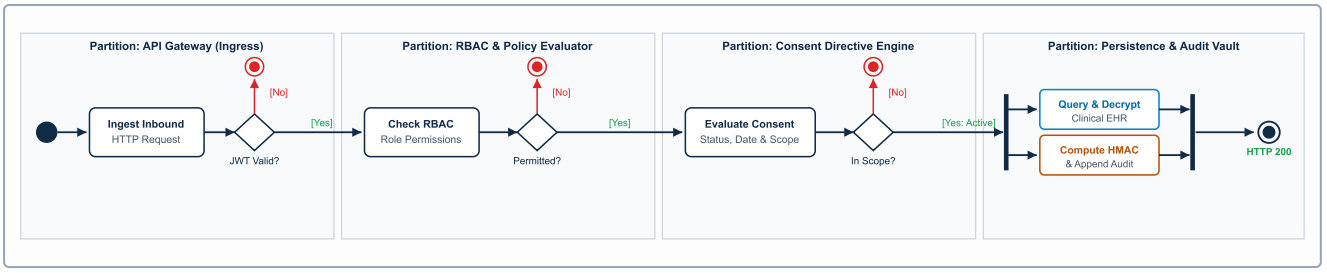
1. **Credential & Role Introspection (Step 1–2):** The API Gateway extracts the cryptographically signed JWT bearer token, authenticates identity claims, and confirms the caller holds the `HEALTHCARE_PROVIDER` role privilege mask.
2. **Dynamic Consent Directive Evaluation (Step 3):** The `ConsentEngine` performs an indexed query on table `CONSENT_RECORDS` matching `patient_id`, `provider_id`, and current UTC timestamp. The directive must satisfy: `status == 'ACTIVE'`, `valid_from <= now() <= valid_until`, and `requested_category ∈ access_scope`.
3. **Authorized Materialization Branch (Steps 4–6):** If valid consent exists, the clinical data layer fetches encounter summaries and diagnostic observations, computes the SHA-256 event signature, commits the audit record, and returns HTTP 200 OK.
4. **Immediate Revocation Interception (Steps 7a–7b):** If the patient recently revoked the consent (UC-03), or if the validity window expired, access is blocked immediately at the gateway layer, returning HTTP 403 Forbidden without database query leakage.

> **Zero-Trust Clinical Isolation:** As established in SRS Section 4.5 and Business Rule BR-02, clinical read operations never default to implicit hospital trust. Even attending department heads require active explicit consent directives registered in the database.

5. Scenario 3: Activity Diagram — Dynamic Consent & Security Pipeline

ACTIVITY DIAGRAM

The Activity Diagram below maps the server-side verification algorithm (SRS Appendix B.4, Algorithm 1). It formalizes concurrent token processing, conditional branching, decision diamonds, and fork/join synchronization for all protected clinical read and write operations.



6. Activity Execution Flow & Concurrency Governance

WORKFLOW LOGIC

The activity pipeline processes inbound clinical requests strictly through sequential and concurrent synchronization barriers:

- **Guard 1 [JWT Valid?]:** Intercepts tampering, unverified signatures, or expired tokens. Failure immediately terminates execution at the API Gateway with HTTP 401 Unauthorized without consuming internal service CPU cycles.
- **Guard 2 [Role Permitted?]:** Evaluates the decoded role mask against endpoint privilege configurations (REQ-RBAC-002). Non-provider roles querying clinical endpoints immediately terminate with HTTP 403 Forbidden.
- **Guard 3 [Consent Scope Valid?]:** Dynamic database query checks active directives. If revoked or unconsented, a security audit entry is written and an immediate 403 Consent Denied response is returned.
- **Fork & Join Synchronization:** When all guards succeed, execution forks: the database transaction decodes the clinical entities while the audit dispatcher computes the SHA-256 HMAC event signature in parallel. The join barrier guarantees the audit entry commits before the TLS payload returns to the caller.

> **ACID & Non-Repudiation Assurance:** In accordance with REQ-AUDIT-007 and REQ-SAFE-002, the parallel branches are bound within the service boundary. If the audit append fails, the entire transaction rolls back, preventing unlogged clinical disclosures.

7. Sequence & Activity Traceability to SRS Requirements & Use Cases

TRACEABILITY MATRIX

The table below provides bidirectional traceability between behavioral diagram elements, SRS v2.0 functional requirements, and Use Case specifications:

Use Case ID	Diagram Scenario Modeled	Lifelines / Activity Partitions	SRS Requirements Verified
UC-01	User Authentication & TOTP MFA Verification (Scenario 1)	`ClientApp`, `ApiGateway`, `AuthService`, `Argon2Vault`, `TotpEngine`	REQ-AUTH-001–008, REQ-SEC-004, REQ-SEC-005, Business Rule BR-01
UC-02, UC-03	Dynamic Consent Evaluation & EHR Retrieval (Scenario 2)	`ProviderClient`, `ApiGateway`, `ConsentEngine`, `ClinicalRecordSvc`	REQ-REC-001–008, REQ-CONSENT-001–008, BR-02, BR-03
UC-04, UC-06	Clinical Encounter & E-Prescription Creation	`ProviderClient`, `EncounterController`, `RxService`, `Database`	REQ-ENC-001–005, REQ-TREAT-001–005, REQ-SAFE-001
UC-05, UC-07	Diagnostic Report Upload & SHA-256 Hashing	`ProviderClient`, `DocumentService`, `S3Vault`, `AuditVault`	REQ-DIAG-001–006, REQ-DOC-001–006, REQ-SAFE-002
UC-08	Administrative Role Provisioning & Clinical Isolation	`AdminConsole`, `UserManagementService`, `RbacEngine`	REQ-RBAC-001–007, Business Rule BR-04 (Duty Separation)
UC-09	Immutable Compliance Audit Log Review & Export	`AuditorClient`, `AuditController`, `ImmutableAuditVault`	REQ-AUDIT-001–007, REQ-SAFE-004, Appendix B.4 Pipeline
UC-10	External FHIR R5 Clinical Resource Exchange	`ExternalHospital`, `FhirGateway`, `Sanitizer`, `Database`	REQ-INT-001–005, REQ-COMM-005, RFC 7807 Errors

8. Behavioral Software Architecture & Dynamic Design Patterns

DESIGN PATTERNS

• **Intercepting Filter Pattern:** Implemented at the API Gateway to enforce stateless token authentication, Rate Limiting, and CORS before routing calls to downstream microservices.
• **Guarded Suspension / Policy Strategy:** The `ConsentEngine` evaluates dynamic Boolean expressions against relational records before authorizing data queries.
• **Asynchronous Event Observer:** Clinical mutations publish immutable log events to Kafka/Redis queues, guaranteeing decoupling between transaction latency and write-once audit storage.

9. Faculty Guide Evaluation & Academic Sign-Off Block

EVALUATION

Faculty Guide Evaluation Remarks:

The sequence diagrams, activity workflows, lifeline boundaries, guard conditions, and traceability matrices conform to ISO/IEC/IEEE 29148 standards and the DHRMS Version 2.0 technical baseline. The dynamic models successfully demonstrate rigorous verification of access control, dynamic consent evaluation, and audit logging.

Status: APPROVED **Lab Grade:** _____ / 10

Faculty Supervisor:
Mr. Navdesh Singh
Dept. of Computer Science & Engg.

Faculty Signature & Date

Prepared by: Abhinav Singh (202401100200014), Abhinav Pathak (202401100200013), Abhishek Kumar Verma (202401100200015), Abhishek Yadav (202401100200016)